

Table of Contents

Cisco Secure Workload — NIST SP 800-82 Rev. 3

Reference Design | IT-Side Boundary to OT / ICS Environments

Version: 1.0

Framework: NIST Special Publication 800-82 Revision 3 — *Guide to Operational Technology (OT) Security* (NIST, September 2023)

Use Case: IT-side segmentation of OT zones, IT/OT DMZ workload control, OT-adjacent monitoring service segmentation, IT/OT communication path evidence

Framework version note. NIST SP 800-82 Rev. 3 is *guidance*, not a separate control catalogue. It uses NIST SP 800-53 Rev. 5 as its underlying control framework and provides an OT-tailored overlay and OT-specific guidance. This reference design references **800-82 topic areas** (e.g. cybersecurity programme, network architecture, segmentation, incident response) and the **800-53 control families** the overlay aligns to. Specific control selection and tailoring must be done against the customer's OT cybersecurity programme and the 800-53 baseline they apply.

Scope boundary. CSW is a workload-segmentation product. The deep OT device layer (PLCs, RTUs, HMIs, controllers, OT protocols like Modbus, DNP3, S7, OPC UA) is **not** within CSW's direct enforcement scope and is better addressed by an OT-native product (e.g. Cisco Cyber Vision, Claroty xDome, Nozomi). CSW's role is to harden the **IT-side workloads adjacent to OT** — historians, engineering workstations, jump hosts, IT/OT DMZ workloads, asset / vulnerability servers, and monitoring servers — and to evidence the IT-side of the IT/OT communication boundary.

CSW UI navigation note. Cisco does not yet publish 800-82-specific CSW UI navigation; framework-specific paths are on the product roadmap. This reference design describes CSW *capabilities* and the *evidence artifacts* they produce.

Reader's Guide

Who this is for. Industrial / critical infrastructure operators (manufacturing, energy, water, transportation, pharma, food production) and any organisation with an OT estate whose IT-side boundary must demonstrate segmentation hygiene; CISO / OT security lead, IT and OT engineering, internal audit, and consultants preparing a 800-82-aligned assessment.

Questions this reference design helps you answer:

- *Can I demonstrate that IT workloads with reach into the IT/OT DMZ or into OT zones are inventoried, classified, and segmented?* (800-82 network architecture topic; 800-53 AC, SC, CM families)
- *Can I evidence that the IT/OT communication boundary is constrained to approved flows only?* (800-82 segmentation; 800-53 SC-7 / AC-4)
- *Can I produce monitoring evidence on the IT side of the IT/OT boundary?* (800-82 monitoring topic; 800-53 SI-4 / AU family)
- *Can I prioritise patching of IT-side workloads whose reachability is into OT zones?* (800-82 vulnerability management; 800-53 RA / SI-2)
- *In the event of an incident, can I reconstruct IT-side workload flow to/from OT zones?* (800-82 incident response; 800-53 IR family)

What you'll need. IT asset inventory, OT asset inventory (from your OT-native product), an architecture diagram showing IT zones, IT/OT DMZ, and OT zones (e.g. ISA-95 levels 3.5–4), the OT cybersecurity programme document, and a list of historians / engineering workstations / IT/OT DMZ workloads in scope.

Where to start. Sections 1–4 if you are scoping; 5–7 if you are designing and simulating policy; 9–10 if you are preparing an assessment / audit pack within the next quarter.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥ 2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope

- ❑ ADM-imported rules refined; Simulation run ≥ 1 week
- ❑ Change tickets for false-positive fixes; exception register updated
- ❑ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ❑ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ❑ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ❑ SIEM integration verified (sample events)
- ❑ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- OT-adjacent IT segmentation (jump hosts, historians, patch repos)
- Pair with OT visibility for end-to-end zones
- Vendor access path documentation

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

NIST SP 800-82 Rev. 3 is OT-tailored guidance over NIST SP 800-53 Rev. 5. Its key technical themes for the IT-side workload layer are:

- A **cybersecurity programme** that integrates OT considerations
- A **network architecture** that segregates IT from OT (commonly described as ISA-95 levels with a DMZ at level 3.5 between the manufacturing zone (3) and the enterprise zone (4–5))
- Continuous **monitoring** with OT-tailored considerations (e.g. minimising disruption)
- **Access control** at zone boundaries
- **Vulnerability management** with OT-specific change-management constraints
- **Incident response** with OT-specific operational concerns

CSW supports the **IT-side** of these themes by:

- Inventorying IT-side workloads adjacent to the OT estate
- Producing reachability evidence into the IT/OT DMZ and across the boundary
- Enforcing workload-level allowlist policy at the IT/OT boundary on the IT side
- Producing monitoring telemetry and policy-violation alerts
- Producing reachability-weighted vulnerability evidence so patch prioritisation reflects OT-adjacency
- Producing forensic flow + process timelines on the IT side for incident response

What CSW does **not** do for 800-82: enforce policy on OT devices, parse OT protocols, manage OT change windows, replace the OT-native product, or replace the OT cybersecurity programme.

800-82 Topic Areas and CSW Relevance

800-82 topic area	CSW relevance (IT side)	Underlying 800-53 control family (representative)
OT cybersecurity programme	Evidence inputs (inventory, telemetry)	PM family
Network architecture and segmentation	Workload-level segmentation on IT-side; ADM-derived allowlist; policy workspace	SC-7, AC-4
Monitoring	Continuous flow / process telemetry; anomaly alerts	SI-4, AU family
Access control	Workload-to-workload allowlist on IT side	AC-3, AC-4, AC-6
Vulnerability management	Reachability-weighted CVE evidence	RA-5, SI-2
Incident response	Forensic flow / process telemetry	IR family
Configuration / change management	Baseline policy workspace + change log	CM family

2. Pre-Deployment Checklist

- ☐ CSW cluster provisioned
- ☐ Sensor compatibility verified on **IT-side** workloads only (historians, engineering workstations, IT/OT DMZ workloads, jump hosts, asset / vulnerability servers, monitoring servers). Do not install CSW sensors on OT devices.
- ☐ OT-native product (Cyber Vision / Claroty / Nozomi) confirmed for OT zones
- ☐ IT/OT architecture diagram reviewed; the IT/OT DMZ boundary defined unambiguously
- ☐ Stakeholders: CISO, OT security lead, OT operations lead, internal audit

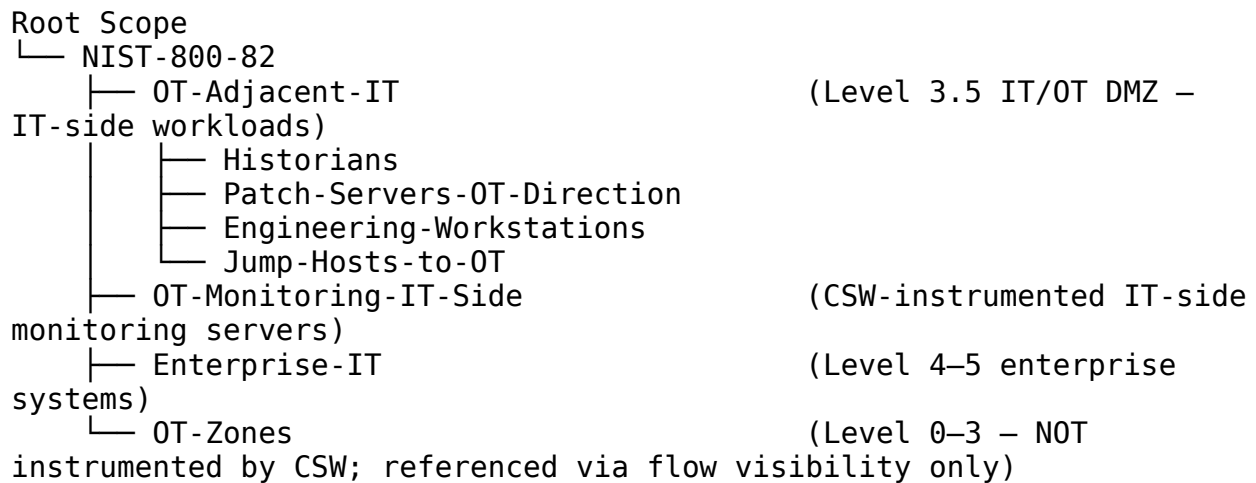
- ❑ Change windows agreed with OT operations (sensor install on engineering workstations is operationally sensitive)
 - ❑ Evidence retention agreed with internal audit and OT engineering
-

3. Phase 1 — IT-Side Sensor & Connector Deployment (Days 1–5)

- Install software sensors only on **IT-side** workloads in monitoring mode
 - Connect cloud accounts for cloud-hosted IT workloads in scope (e.g. cloud historian, cloud SCADA front-end)
 - Day-1 labels: `application`, `env`, `isa_level`, `it_or_ot`, `criticality`, `owner`, `compliance=nist-800-82`
 - Maintain a `cannot-instrument` register for OT devices and any appliances; this register is itself evidence (it documents the boundary of CSW's coverage)
 - Retain Phase-1 sensor inventory baseline
-

4. Phase 2 — IT/OT Scope Architecture (Days 6–10)

4.1 Suggested Scope Architecture



CSW will **not** have sensors inside OT-Zones; it observes the IT-side endpoint of every IT ↔ OT flow.

4.2 Inventory Filters

Filter: OT-Adjacent-IT-Candidates

- Tag: `it_or_ot` = `it-side`
- Tag: `isa_level` = 3.5
- Hostname / app pattern matches: `historian`, `engineering`, `ot-jump`

Filter: Jump-Hosts-to-OT

- Listening port: 22, 3389
- Tag: `purpose` = `ot-admin`

4.3 Labeling Strategy

Label key	Example values	Why it matters for 800-82
isa_level	4, 3.5, 3, 2, 1	Reflects ISA-95 architectural level commonly used in 800-82 references
it_or_ot	it-side, ot-side	Anchors the boundary CSW evidences
application	historian, mes, engineering-workstation	Maps workloads to OT-adjacent systems
env	production, dev, lab	Production OT-adjacent workloads need stricter controls
criticality	critical, important, standard	Risk tiering
owner		Accountability
compliance	nist-800-82	Filters CSW evidence to 800-82 scope
.		

5. Phase 3 — Application Dependency Mapping (Days 11–21)

Run ADM on the IT-side scopes. For 800-82, the most important questions are about **boundary** flows:

Question	800-82 / 800-53 reference
Which IT workloads communicate with OT-Zones, and on what ports / protocols?	SC-7, AC-4
Which IT workloads in OT-Adjacent-IT communicate with Enterprise-IT?	SC-7, AC-4
Are flows into OT-Zones constrained to approved historians, engineering workstations, or jump hosts?	AC-3, AC-4, AC-6
Are jump-host flows to OT-Zones audited?	AC-6, AU family
Which IT-side OT-adjacent workloads have direct or transitive reach to the internet?	SC-7

Use ADM to confirm or correct `isa_level`, `it_or_ot`, and `application` labels.

6. Phase 4 — Policy Development (Days 22–35)

6.1 800-82-Aligned Policy Framework (IT side)

Absolute policies:

DENY Enterprise-IT direct enterprise → OT)	→ OT-Zones	(no
DENY OT-Adjacent-IT direct internet egress from OT-adjacent IT)	→ Internet	(no
DENY Any deny inbound from the IT side)	→ OT-Zones	(default

Allowlist policies (examples to adapt per environment):

ALLOW Historians tcp/<approved-ot-protocol-via-DMZ>	→ OT-Zones	
ALLOW Engineering-Workstations tcp/<approved-engineering-protocol>	→ OT-Zones	
ALLOW Jump-Hosts-to-OT tcp/3389	→ OT-Zones	tcp/22,
ALLOW OT-Adjacent-IT	→ OT-Monitoring-IT-Side	tcp/443
ALLOW Patch-Servers tcp/<approved-update-port>	→ OT-Adjacent-IT	

Catch-all (audit everything else):

LOG Any (unmatched inbound)	→ OT-Adjacent-IT
LOG OT-Adjacent-IT (unmatched outbound)	→ Any

6.2 Policy Workspace Lifecycle

Even more conservative than IT-only frameworks; OT operations cannot tolerate accidental denial:

Phase	Mode	Duration	Purpose
1	Simulation	4 weeks	Validate against live traffic; long observation window for OT cycles
2	Enforcement of high-confidence rules only	2 weeks	Enterprise → OT deny, internet egress deny
3	Full Enforcement on IT side	Ongoing	OT-side enforcement remains with the OT-native

Phase	Mode	Duration	Purpose
			product

Snapshot the workspace at every phase transition; this is evidence for SC-7 / AC-4 / CM family.

7. Phase 5 — 800-82 Topic Mapping with CSW Evidence

800-82 topic	What CSW produces	How to use it (800-53 family)
Network architecture and segmentation	Policy workspace; observed IT ↔ OT flows; ADM-derived allowlist	SC-7, AC-4 evidence on the IT side of the boundary
Monitoring	Continuous flow / process telemetry; alerts on unauthorised IT ↔ OT flow	SI-4, AU family
Access control	Workload-to-workload allowlist + enforcement log	AC-3, AC-4, AC-6
Vulnerability management	Reachability-weighted CVE on OT-adjacent IT workloads	RA-5, SI-2
Incident response	Forensic flow / process search across the incident window	IR family
Configuration management	Workspace snapshot before/after each change	CM family

8. Phase 6 — Vulnerability Management (IT-side, OT-aware)

OT environments often have constrained patch windows. CSW's role on the IT side:

Priority 1: Critical CVE on OT-Adjacent-IT with inbound reachability

Priority 2: Critical CVE on Jump-Hosts-to-OT

Priority 3: Critical CVE on Patch-Servers / OT-Monitoring-IT-Side

If a patch must be delayed (common in OT-adjacent environments), use CSW to:

- Restrict the vulnerable port to an explicit approved source list
- Add an anomaly alert on the affected process
- Log all connections to the affected workload
- Document the exception in the policy workspace exception register

The exception register itself is evidence for RA / SI-2 risk acceptance and CM change control.

9. Phase 7 — Monitoring & Alerting

Alert	Trigger	800-82 topic
Unapproved IT → OT flow	New flow from any IT workload → OT-Zones outside approved baseline	Segmentation
Enterprise → OT attempt	Enterprise-IT → OT-Zones (any)	Segmentation
Jump-host activity outside change window	Jump-Hosts-to-OT → OT-Zones outside an authorised change window	Access control
Plaintext on regulated paths	HTTP / unencrypted protocol from OT-Adjacent-IT	Communications (detection)
Policy violation	Enforced policy block triggered	Segmentation / Access control
Sensor offline	Agent stops reporting on an OT-Adjacent-IT workload	Monitoring evidence integrity

9.2 Forensic Telemetry

Per incident, retain on the IT side:

- Flow log scoped to affected IT workload(s) and time window (with process context)
 - Process search output
 - Policy workspace state at the time of the incident
 - Vulnerability snapshot for the affected workload(s)
 - Pair with the OT-native product's view of the OT side to produce a complete picture
-

10. Reporting & Evidence Collection

10.1 Evidence per Audit Cycle (quarterly recommended)

Evidence item	CSW source area	800-82 topic
IT-side workload inventory adjacent to OT	Inventory export	Programme / asset evidence
Scope + label membership (<code>isa_level</code> ,	Scope membership export	Segmentation

Evidence item	CSW source area	800-82 topic
it_or_ot)		
Approved vs. observed IT ↔ OT flows	ADM workspace export	Segmentation
Policy workspace snapshot	Policy workspace export	Segmentation / change control
Policy enforcement / violations	Policy analysis output	Access control / monitoring
Vulnerability + reachability (OT- adjacent IT)	Vulnerability report scoped to NIST-800-82	Vulnerability management
Jump-host activity report	Flow search on Jump- Hosts-to-OT	Access control / monitoring
Incident timeline (IT- side)	Flow + process search	Incident response
Exception register	Policy workspace exceptions list	Configuration / risk acceptance

10.2 Ongoing Compliance Posture

- **Monthly:** scope / inventory hygiene; jump-host activity review
- **Quarterly:** policy workspace review; refresh evidence pack 10.1
- **Annually:** independent walk-through with OT engineering and internal audit
- **Continuously:** policy drift detection; ADM re-run every 90 days

11. Common Pitfalls

Pitfall	Mitigation
Trying to instrument OT devices with CSW	Use an OT-native product for OT devices; CSW is for IT-side workloads
Treating 800-82 as a standalone control catalogue	800-82 is OT-tailored guidance over 800-53; cite 800-53 controls for the actual control language
Skipping the simulation window for OT-adjacent workloads	Use a 4-week simulation; OT cycles are long
Enforcing IT-side rules without coordinating with OT operations	All policy enforcement on OT-adjacent IT requires OT engineering sign-off
Assuming network protocol by port (e.g. Modbus on TCP/502)	Confirm by process + observed handshake where possible; OT protocols vary
Treating CSW jump-host visibility as	CSW shows the flow; session-level

Pitfall	Mitigation
session monitoring	command recording is a PAM responsibility

Related Frameworks in This Repository

- [NIST SP 800-53 Rev 5](#) — the control catalogue underlying 800-82
- [NERC CIP](#) — for North American Bulk Electric System operators
- [TSA Pipeline](#) — for US pipeline operators
- [IEC 62443](#) — adjacent OT cybersecurity standard
- [UK NCSC CAF v3.2](#) — OT-adjacent IT segmentation is the reuse path for CAF B5.

Document prepared for Cisco industrial / critical-infrastructure engagements. Replace [Customer Name] and any bracketed fields before customer delivery. CSW addresses the IT-side workload boundary only; pair with an OT-native product for OT device coverage.